

Assinatura de Código e Atualizações de Software Pós-Quânticas: Protegendo a Cadeia de Suprimentos de Software com ML-DSA e SLH-DSA

Day 06 | Category: Cadeia de Suprimentos de Software e Segurança de Firmware Date: 2026-07-13 | **DAILY**

MONITORING

À medida que a era da computação quântica se aproxima, a cadeia de suprimentos de software (software supply chain) tornou-se um dos alvos mais críticos para adversários cibernéticos. No coração da segurança de software está a assinatura digital, que garante que as atualizações do sistema operacional, instalações de aplicativos e firmware de hardware venham de fontes confiáveis e não tenham sido alteradas. Embora a proteção do tráfego de internet ativo com trocas de chaves híbridas (como X25519 + ML-KEM) já esteja amplamente difundida em navegadores e SSH, a transição do ecossistema de **distribuição de software e assinaturas de firmware** para a Criptografia Pós-Quântica (PQC) apresenta desafios únicos, particularmente em relação à longevidade da assinatura, velocidades de verificação e restrições de armazenamento em hardware.

O Problema da Integridade de Longo Prazo: Para a navegação web típica, as chaves criptográficas são efêmeras e vivem por milissegundos. No entanto, assinaturas de código e atualizações de firmware são feitas para durar. Se um dispositivo médico, um CLP industrial ou a unidade de controle do motor de um veículo for implantado em 2026 com uma vida útil operacional de 15 anos, suas chaves de verificação de atualização devem permanecer seguras até 2041. Um avanço na computação quântica que comprometa as chaves de assinatura clássicas (RSA ou ECDSA) invalida retroativamente a integridade de todas as atualizações passadas, presentes e futuras, permitindo que atacantes injetem firmware malicioso sem disparar alertas no bootloader.

Os Dois Pilares das Assinaturas Pós-Quânticas: ML-DSA vs. SLH-DSA

Para proteger as assinaturas digitais contra ameaças quânticas, o NIST padronizou dois algoritmos principais de assinatura digital: **ML-DSA** (FIPS 204, baseado em reticulados modulares) e **SLH-DSA** (FIPS 205, baseado em estruturas de hash sem estado - stateless). Cada algoritmo possui características distintas que ditam sua aplicabilidade na cadeia de suprimentos de software:

- **ML-DSA (FIPS 204):** Baseado na dificuldade do problema Module Learning With Errors (MLWE). É um esquema de assinatura de uso geral. Destaca-se por assinaturas rápidas, velocidades de verificação extremamente rápidas e chaves públicas (~1,9 KB para ML-DSA-65) e assinaturas (~3,3 KB) relativamente compactas. É o candidato ideal para distribuição de software geral em alta frequência e larga escala (por exemplo, gerenciadores de pacotes de sistemas operacionais como APT, certificados de assinatura de código seguros e atualizações de lojas de aplicativos).
- **SLH-DSA (FIPS 205):** Baseado estritamente em estruturas de hash sem estado (SPHINCS+). Depende inteiramente da resistência à colisão das funções de hash criptográficas subjacentes (como SHA-2 ou SHAKE/SHA-3). Como o SLH-DSA não faz nenhuma suposição algébrica estrutural, ele é imune a futuras criptoanálises matemáticas que poderiam teoricamente comprometer esquemas baseados em reticulados. No entanto, exige tempos de assinatura significativamente mais longos e gera assinaturas grandes (de ~7,8 KB a ~49 KB). Apesar desse impacto, o tamanho de sua chave pública é minúsculo (~32 bytes), tornando-o o padrão-ouro para aplicações de alta segurança, repositórios de certificados raiz e bootloaders de hardware imutáveis.

Aplicabilidade no Mundo Real em Secure Boot e Atualizações OTA

Na prática, a integração de assinaturas pós-quânticas em protocolos de internet e dispositivos requer navegar por restrições físicas e de rede severas:

1. Raiz de Confiança em Hardware e Secure Boot

Durante o processo de inicialização de um dispositivo, o bootloader seguro verifica o firmware inicial usando uma chave pública gravada permanentemente na memória somente leitura (ROM) do chip ou em fusíveis programáveis uma única vez (OTP). Este ambiente é altamente restrito em termos de recursos. Armazenar uma chave pública ML-DSA de 2 KB em registradores de hardware costuma ser impossível. Em contrapartida, a **chave pública de 32 bytes do SLH-DSA** cabe facilmente em fusíveis de hardware padrão. Mesmo que a verificação de uma assinatura SLH-DSA exija mais ciclos de CPU, o processo de inicialização ocorre com pouca frequência, tornando o tamanho minúsculo da chave pública o fator decisivo para os fabricantes de hardware.

2. Atualizações Over-the-Air (OTA) em IoT e Sistemas Embarcados

Dispositivos IoT e sistemas embarcados implantados em redes industriais remotas (como redes elétricas inteligentes, sensores de telemetria) geralmente dependem de produtos de baixa largura de banda, como redes celulares, satélite ou LPWAN. Transportar uma assinatura SLH-DSA de 17 KB para uma pequena atualização de configuração de 50 KB representa um consumo massivo que esgota a bateria do dispositivo e consome dados de rede. Nesses cenários, os desenvolvedores estão recorrendo ao **ML-DSA-44 ou ML-DSA-65**, que oferecem um equilíbrio ideal entre tamanho de assinatura e processamento computacional, ou implantando **assinaturas**

híbridas que combinam ECDSA clássico com ML-DSA para garantir compatibilidade reversa e resistência quântica.

3. Assinatura de Pacotes de Sistemas Operacionais

Distribuições Linux e fornecedores de software empresarial devem assinar milhões de pacotes individuais. A velocidade de assinatura é crítica para pipelines de integração e entrega contínua (CI/CD). Enquanto o SLH-DSA pode levar centenas de milissegundos para gerar uma única assinatura, o ML-DSA pode assinar em menos de um milissegundo, tornando o ML-DSA a única opção viável para ciclos de lançamento de software automatizados e de alto volume.

Comparando Esquemas de Assinatura para a Cadeia de Suprimentos de Software

Esta tabela compara os algoritmos de assinatura clássicos com os novos padrões pós-quânticos sob o FIPS 204 e FIPS 205, destacando seus trade-offs técnicos:

Nome do Algoritmo	Tipo / Classe	Tamanho da Chave Pública	Tamanho da Assinatura	Velocidade de Assinatura	Velocidade de Verificação	Melhor Adequado Para
ECDSA (P-256)	Clássico (Curva Elíptica)	~64 Bytes	~64 Bytes	Muito Rápida	Rápida	Não recomendado (quebrado pelo Algoritmo de Shor)
RSA-3072	Clássico (Fatoração de Inteiros)	~384 Bytes	~384 Bytes	Lenta	Muito Rápida	Não recomendado (quebrado pelo Algoritmo de Shor)
ML-DSA-65 (FIPS 204)	Pós-Quântico (Reticulados Modulares)	1.952 Bytes	3.293 Bytes	Muito Rápida	Muito Rápida	Assinatura de software geral, pacotes de S.O., lojas de apps, pipelines de CI/CD.

Nome do Algoritmo	Tipo / Classe	Tamanho da Chave Pública	Tamanho da Assinatura	Velocidade de Assinatura	Velocidade de Verificação	Melhor Adequado Para
SLH-DSA-SHA2-128s (FIPS 205)	Pós-Quântico (Hash sem Estado)	32 Bytes	7.856 Bytes	Muito Lenta	Moderada	Atualizações de firmware de alta segurança, chaves ROM de Secure Boot, ACs Raiz.
SLH-DSA-SHA2-128f (FIPS 205)	Pós-Quântico (Hash sem Estado)	32 Bytes	17.088 Bytes	Moderada	Rápida	Aplicações que exigem verificação mais rápida, onde o tamanho da assinatura é secundário.

Quiz Diário: Teste seu Conhecimento

1. Por que o SLH-DSA (FIPS 205) é considerado estruturalmente mais seguro do que o ML-DSA (FIPS 204) para âncoras de confiança de assinatura de código de longo prazo, apesar de possuir assinaturas maiores e velocidades de assinatura mais lentas?

A) Porque o SLH-DSA exige controle de estado e rastreamento de índices de assinatura, o que impede ataques de repetição de chaves.

B) Porque o SLH-DSA é um esquema baseado em hash sem estado (stateless) que depende apenas de funções de hash seguras, com zero suposições algébricas estruturadas (como reticulados) que poderiam ser comprometidas por futuros avanços matemáticos.

C) Porque o SLH-DSA é mais rápido para assinar em hardware de microcontroladores restritos.

Resposta Correta: B. Como o SLH-DSA depende unicamente da resistência à colisão de funções de hash padrão (como SHA-2 ou SHA-3), ele não depende da complexidade de problemas de reticulados. Ele é matematicamente mais simples e menos vulnerável a futuras quebras criptográficas de natureza algébrica.

2. Qual característica do SLH-DSA o torna altamente atraente para armazenamento em ROM de inicialização segura (Secure Boot) e fusíveis programáveis uma única vez (OTP) de hardware?

A) Seu tamanho massivo de assinatura, que preenche o armazenamento para evitar estouros de buffer (buffer overflows).

B) Sua velocidade de assinatura muito rápida, que acelera as linhas de programação na fábrica.

C) Seu tamanho excepcionalmente minúsculo de chave pública de apenas 32 bytes, que cabe facilmente em registradores de fusíveis de chip limitados.

Resposta Correta: C. Chips de alta segurança têm espaço de ROM/OTP extremamente limitado para armazenar a âncora de confiança (chave pública). A chave pública do SLH-DSA tem apenas 32 bytes (igual ou menor que as chaves clássicas de ECC/RSA), facilitando incrivelmente seu armazenamento em fusíveis físicos do hardware.

3. Um desenvolvedor de software está configurando um pipeline de CI/CD automatizado que assina milhares de microsserviços e pacotes compilados por hora. Qual assinatura pós-quântica (PQC) ele deve selecionar?

A) SLH-DSA-SHA2-128s, para minimizar o tamanho da chave pública em seu banco de dados.

B) ML-DSA-65, porque suas velocidades de assinatura e verificação na casa dos sub-milissegundos evitam gargalos no pipeline mantendo a resistência quântica.

C) XMSS baseado em estado (RFC 8391), porque o pipeline contínuo é perfeito para rastrear estados em instâncias de servidores paralelos.

Resposta Correta: B. Pipelines automatizados de compilação de software de alta frequência

exigem velocidades rápidas de assinatura. O ML-DSA fornece assinaturas e verificações rápidas com tamanhos de assinatura razoáveis, tornando-o a escolha prática para entrega automatizada de software de uso geral.